

SPACE

포너블 세션

기간 9월 14일 ~ 21일

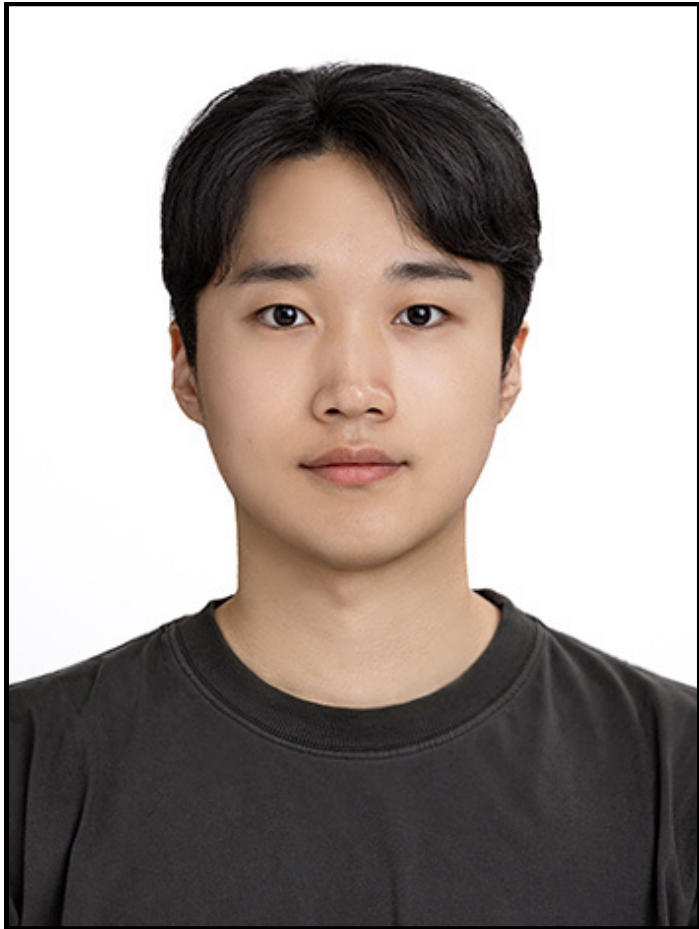
주제 : Stack 마스터하기



INTRODUCE

원우진

HSPACE 취약점 분석가



◆ PROJECT

- 윈도우 소프트웨어 취약점 분석
- 피지컬 ai시스템 공격 표면 식별 및
사이버 보안 위협 분석
- 한국전력공사 홈페이지 취약점 분석
- PDF.js 문법 기반 퍼징

◆ 취약점 제보 경력

- CVE-2025-6218 - Winrar
- CVE-2025-64085 - PDF-XChange Editor
- CVE-2025-69627 - Nitro PDF
- CVE-2026-34378 - OpenEXR
- CVE-2026-34379 - OpenEXR

◆ AWARDS

- DEF CON 34 CTF - 4th
- 2026 AI 원클릭 해킹대회 - 우수상
- 제7회 TS 보안 허점을 찾아라 - 최우수상
- 2025 LLM Safety Challenge - 우수상
- 2025 호남 정보보호 해커톤 - 대상

여러분이 생각하는 CTF란?



포너블 KoTH 모바일 리버싱 윈도우

CONTENTS

목차

●	●	●	●
환경세팅	pwntools	bof	canary
• VMware & Ubuntu 24 • pwntools, pwndbg • IDA	• pwntools란? • pwntools 사용법 • pwntools training	• 프로세스 메모리 구조 • Buffer Overflow란? • 실습	• 카나리란? • 카나리 leak • 실습

00

강의 자료 Download

github.com/pwn2woot/pwn_studylab

01

환경 세팅

- VMware & Ubuntu 24
- pwntools, pwndbg
- IDA



01 환경세팅 VMware

The screenshot shows the Broadcom website's homepage. At the top, there is a navigation bar with the Broadcom logo and links for Products, Solutions, Support and Services, Company, and How To Buy. On the right, there are dropdown menus for 'Support Portal' and 'English'. A white callout box with an orange border is positioned over the 'Support Portal' dropdown, containing a red 'Go To Portal' button, a grey 'Register' button, and a link for 'Forgot Username/Password?'. An orange arrow points from the 'Register' button to a text box that says '1. "Register" 눌러 가입하기'. The main content area features a large banner with the text 'Enabling AI Infrastructure' and a 'Learn More' button. Below the banner, there is a section titled 'What Are You Designing Today?' with icons for various solutions: Broadband Wi-Fi AP Solutions, Data Center Solutions, Financial Services Solutions, Enterprise Security Solutions, Broadband Access, and Automotive. At the bottom, there is a footer with links to the Support Portal, Documents + Downloads, and Security Center. A cookie notice is also visible, stating that Broadcom and third-party partners use cookies to analyze site usage and improve the experience.

1. "Register" 눌러 가입하기

01 환경세팅 VMware

Registration

profile.broadcom.com/web/registration

BROADCOM® Products Solutions Support and Services Company How To Buy

Register Login

Broadcom Support Portal

Enhance your skills through multiple self-service avenues by creating your Broadcom Account

2. 가입에 사용할 이메일 입력

User Registration

Create your Account

Email Address

name@company.com

3. 이미지의 문자 입력

Enter text from image

4. "Next" 클릭

Next

⚠ Use of a shared email account or a distribution list (PDL) is a security risk and a violation of the [Terms of Use](#) for this Site.

Having trouble? [Ask our chatbot](#) for assistance.

01 환경세팅 VMware

The screenshot shows the Broadcom Support Portal homepage. The browser address bar displays `support.broadcom.com/web/ecx/home#`. The top navigation bar includes the Broadcom logo and links for Products, Solutions, Support and Services, Company, and How To Buy. A secondary navigation bar features 'Software ^' and 'Hardware v' menus. The 'Software ^' menu is highlighted with an orange box, and an orange arrow points from a text box to it. The text box contains the Korean text: '12. 브로드컴 포탈 로그인 후 "Software" 클릭' (12. After logging in to the Broadcom portal, click "Software"). Below the navigation bar, a maintenance notice is displayed: 'Support Portal will be undergoing maintenance and will be offline between the hours of 9:30pm and 11:30pm PST, Friday July 11, 2025. We apologize for the inconvenience. To report a priority 1 ticket during this time, please visit our Contact Support page [HERE](#) for the appropriate contact phone numbers.' The main content area features a large image of a modern building at night. Overlaid on this image is a search bar with the text 'Search Support' and a dropdown menu showing 'Broadcom Software'. Below the search bar, a button labeled 'Download Broadcom Support Quick Start Guide' is visible. At the bottom of the page, there is a 'Find Solutions' link and a chatbot icon with the text 'Hi! How may I help you?'.

12. 브로드컴 포탈 로그인 후
"Software" 클릭

Find Solutions

Hi! How may I help you?

01 환경세팅 VMware

The screenshot shows the Broadcom Support Portal interface. The left sidebar contains a list of software categories, with 'VMware Cloud Foundation' highlighted and circled in orange. An orange arrow points from this category to a central menu. In this central menu, 'My Downloads' is circled in orange, and another orange arrow points from it to a final orange box. The bottom of the page features a 'Find Solutions' button and a chatbot icon.

Home - Support Portal - Broadcom

support.broadcom.com/web/ecx/home#

BROADCOM® Products Solutions Support and Services Company How To Buy

Software ^ Hardware v

Mainframe Software +

Enterprise Software +

Cyber Security Software +

Payment Security Software +

Tanzu +

VMware Cloud Foundation

Application Networking and Security +

VeloCloud +

My Dashboard

My Cases

Communities

Product Lifecycle

Service Status

My Entitlements

Documentation

All Products

Partner Portal

My Downloads

Security Advisories

Learnings

Knowledge Base Article

13. "VMware Cloud Foundation" 클릭

14. "My Downloads" 클릭

Find Solutions

Hi! How may I help you?

https://support.broadcom.com/group/ecx/downloads?segment=VC

01 환경세팅 VMware

My Downloads - Support Port

support.broadcom.com/group/ecx/downloads?

BROADCOM® Products Solutions Support and Services Company How To Buy

My Downloads

All Divisions Search Product Name Show Results

Free Software Downloads available [HERE](#)

15. "Here" 클릭

No data found

Products Solutions Support and Services Company How to Buy

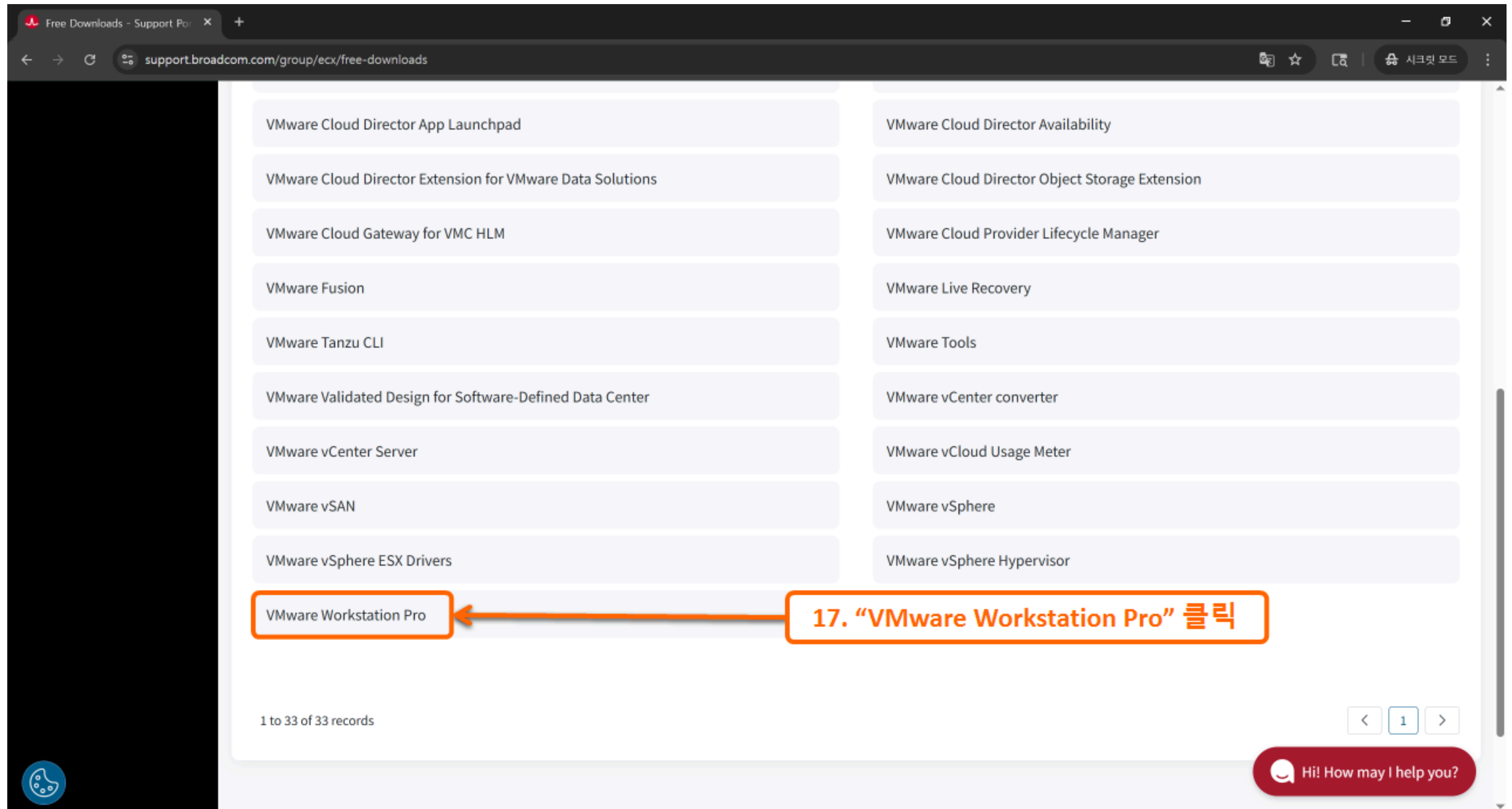
Copyright © 2005-2024 Broadcom. All Rights Reserved. The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries.

Accessibility Privacy Supplier Responsibility Terms of Use Site Map

Hi! How may I help you?

https://support.broadcom.com/group/ecx/free-downloads

01 환경세팅 VMware



01 환경세팅 VMware

ProductFiles - Support Portal

support.broadcom.com/group/ecx/productfiles?subFamily=VMware%20Workstation%20Pro&displayGroup=VMware%20Workstation%20Pro%2017.0%20for%20Windows&release=17.6.3&os...

BROADCOM® Products Solutions Support and Services Company How To Buy

← VMware Workstation Pro (For Windows) 17.6.3

Primary Downloads Open Source

Product Download Help

Please click the term link(s), then acknowledge you agree by selecting the checkbox before proceeding with the download

☐ I agree to the [Terms and Conditions](#)

17.6.3 English

Expand All

File Name	Release Date	Last Updated	SHA2	MD5
VMware Workstation Pro for Windows VMware-workstation-full-17.6.3-24583834.exe(401.43 MB) Build Number: 24583834	Mar 04, 2025	Feb 24, 2025	d7c04b4dd1e6bf551693897d4805e99c45198a830c6 361d9af8267b40906857b	de592b18a39513e3414f197ec1a4cb1c

1 to 1 of 1 records

Hi! How may I help you?

21. "Terms and Conditions" 클릭 후 돌아와서 체크박스 체크

01 환경세팅 VMware

The screenshot shows the VMware Workstation Pro (For Windows) 17.6.3 download page. The page includes a sidebar with navigation links, a main content area with a search bar and filters, and a table of download links. Two orange boxes with arrows point to specific elements: one to the 'I agree to the Terms and Conditions' checkbox and another to the download link icon.

22. 체크박스 클릭이 완료되었다면

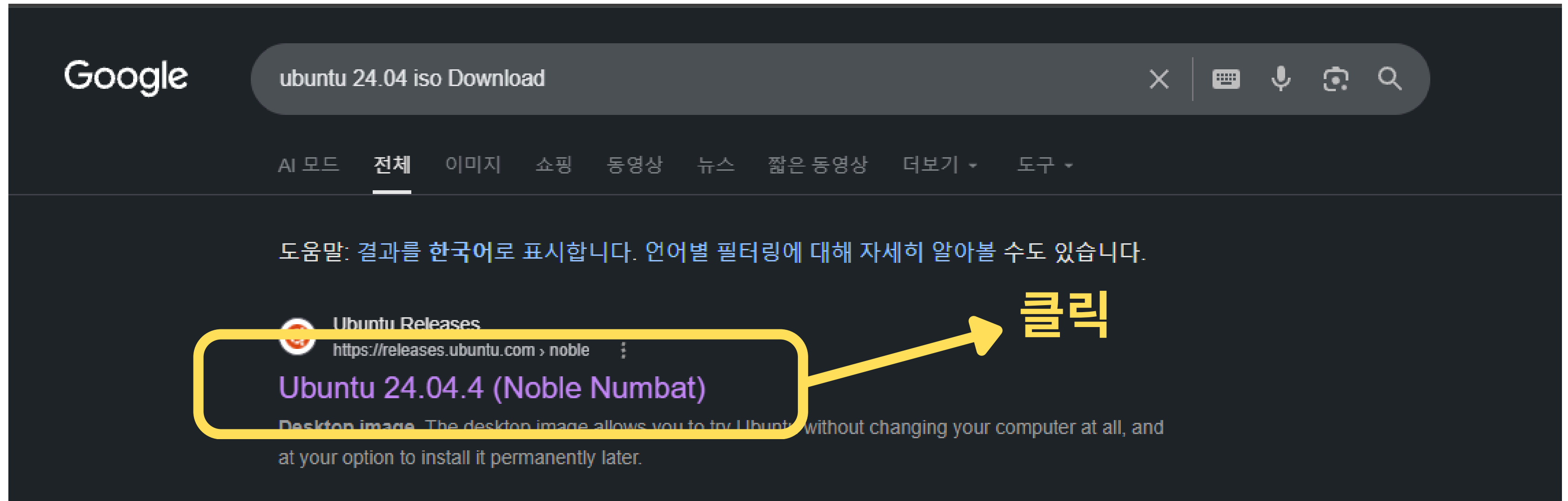
23. 다운로드 클릭

File Name	Release Date	Last Updated	SHA2	MD5
VMware Workstation Pro for Windows VMware-workstation-full-17.6.3-24583834.exe(401.43 MB) Build Number: 24583834	Mar 04, 2025	Feb 24, 2025	d7c04b4dd1e6bf551693897d4805e99c45198a830c6361d9af8267b40906857b	de592b18a39513e3414f197ec1a4cb1c

1 to 1 of 1 records

Hi! How may I help you?

01 환경세팅 Ubuntu 24



ubuntu 24.04 iso Download 검색

01 환경세팅 Ubuntu 24

ubuntu releases

Ubuntu 24.04.4 (Noble Numbat)

Select an image

Ubuntu is distributed on five types of images described below.

Desktop image

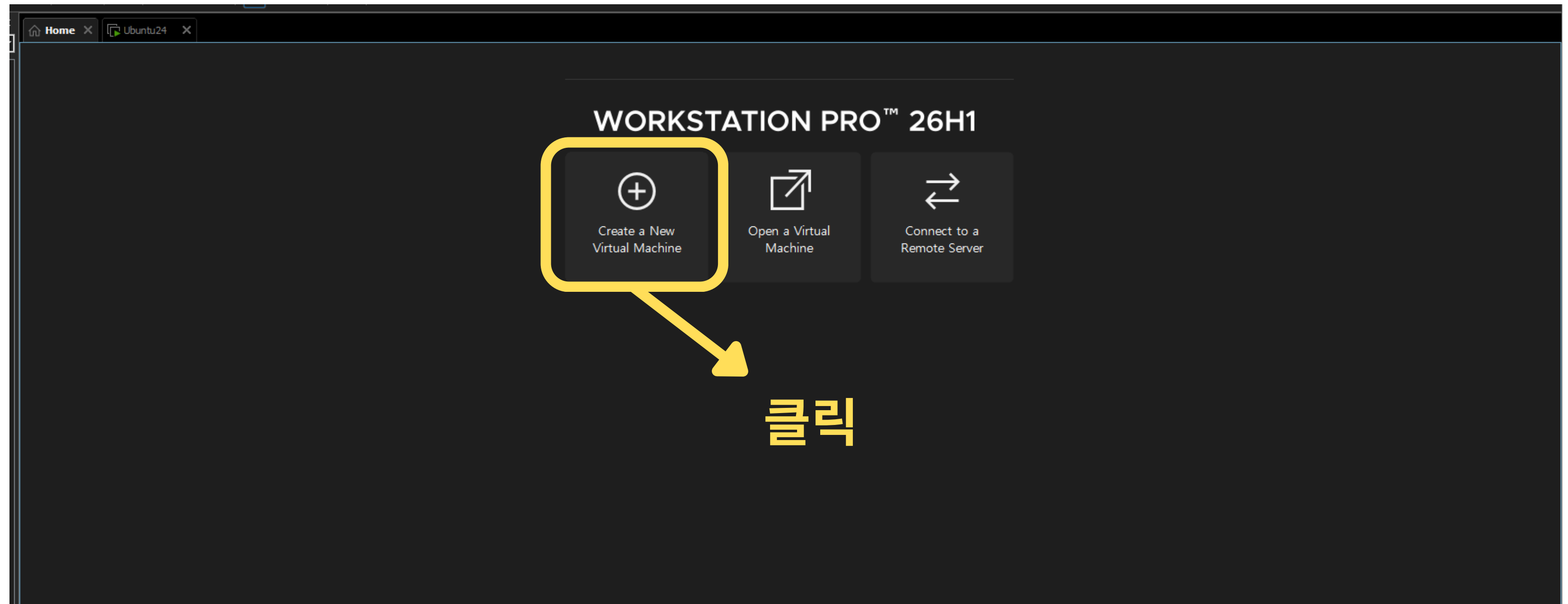
The desktop image allows you to try Ubuntu without changing your computer at all, and at your option to install it permanently later. This type of image is what most people will want to use. You will need at least 1024MiB of RAM to install from this image.

[64-bit PC \(AMD64\) desktop image](#)

Choose this if you have a computer based on the AMD64 or EM64T architecture (e.g., Athlon64, Opteron, EM64T Xeon, Core 2). Choose this if you are at all unsure.

클릭

01 환경세팅 VMware에 ubuntu 설치

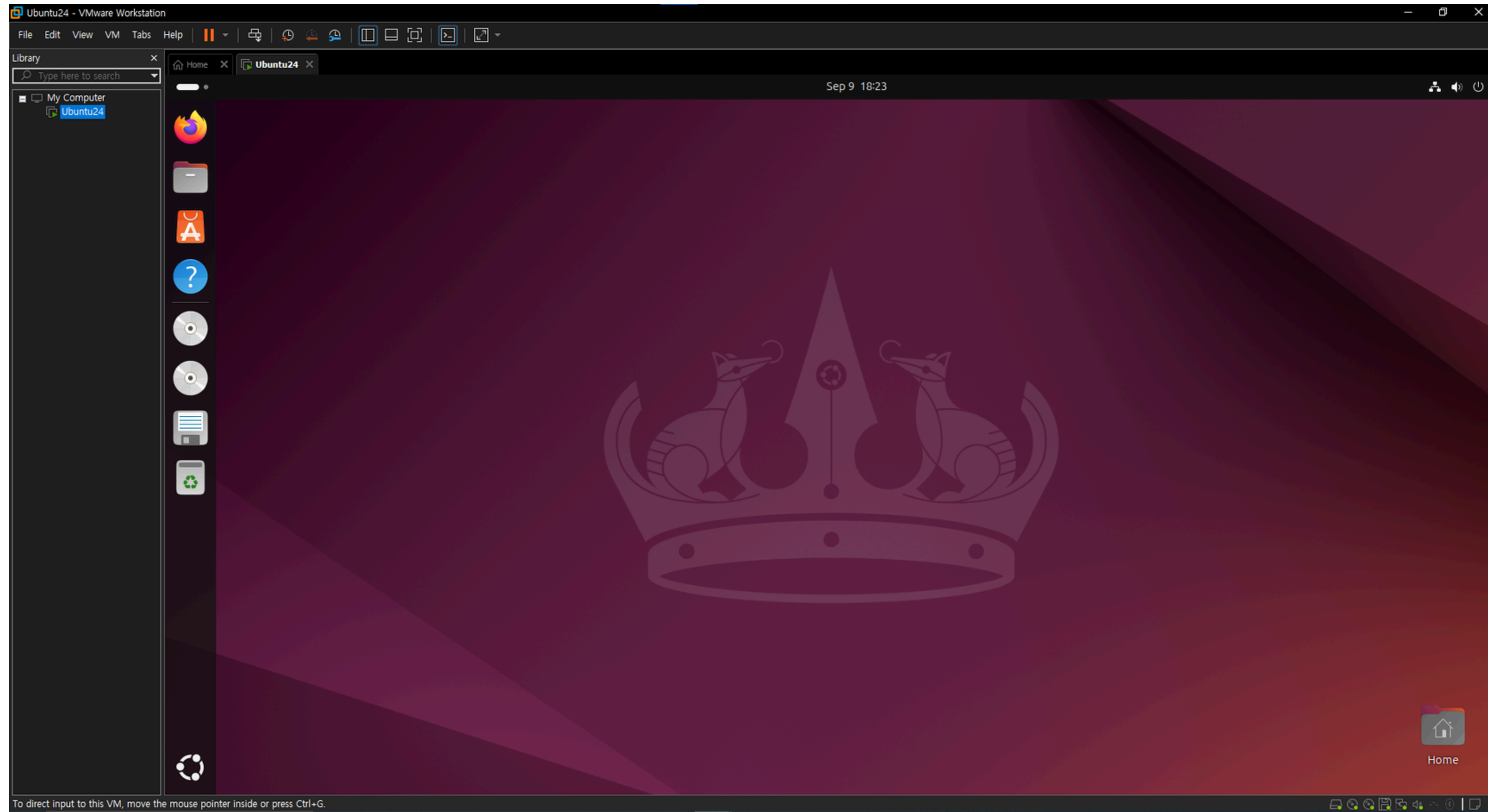


01 환경세팅 VMware에 ubuntu 설치



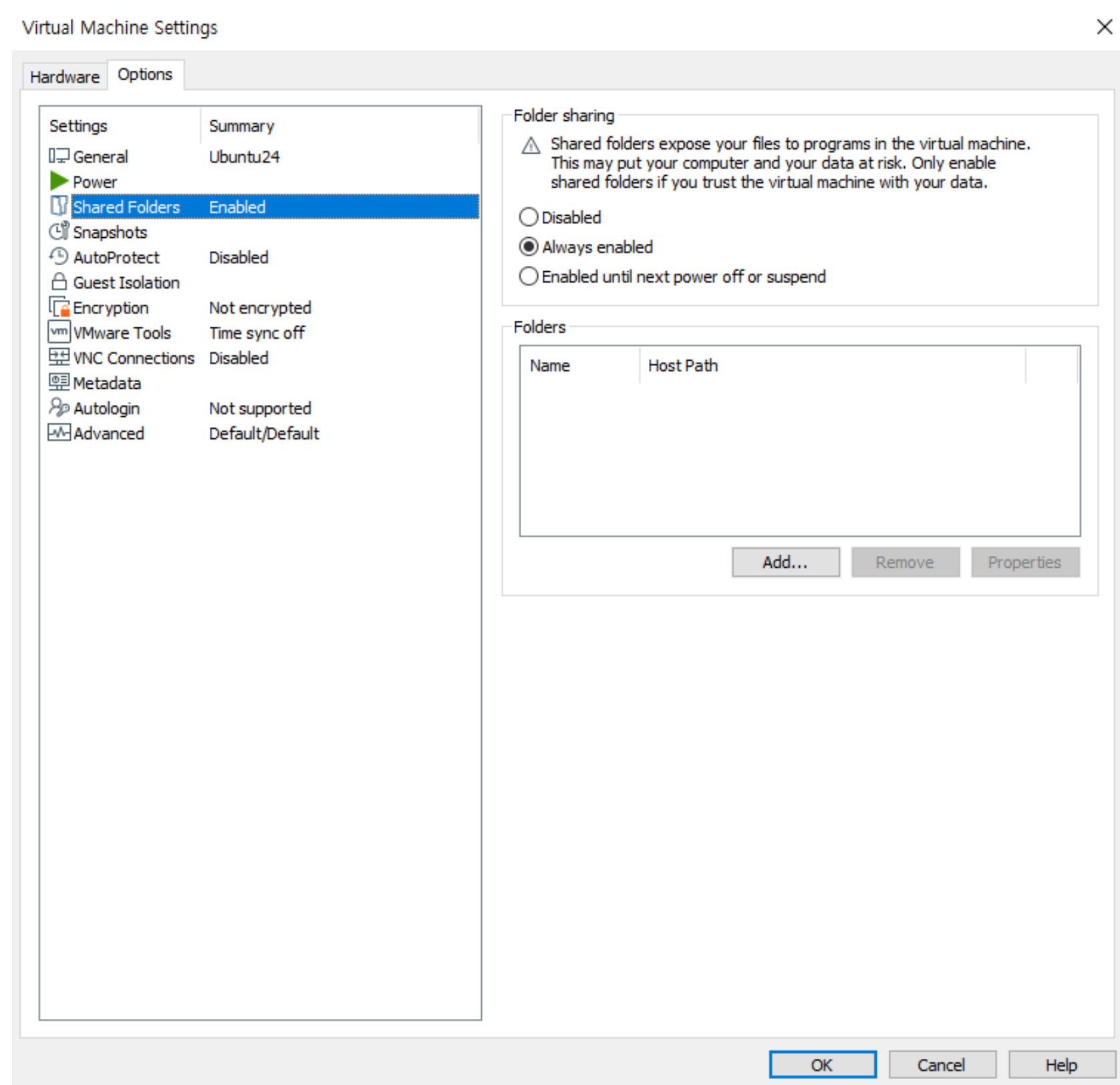
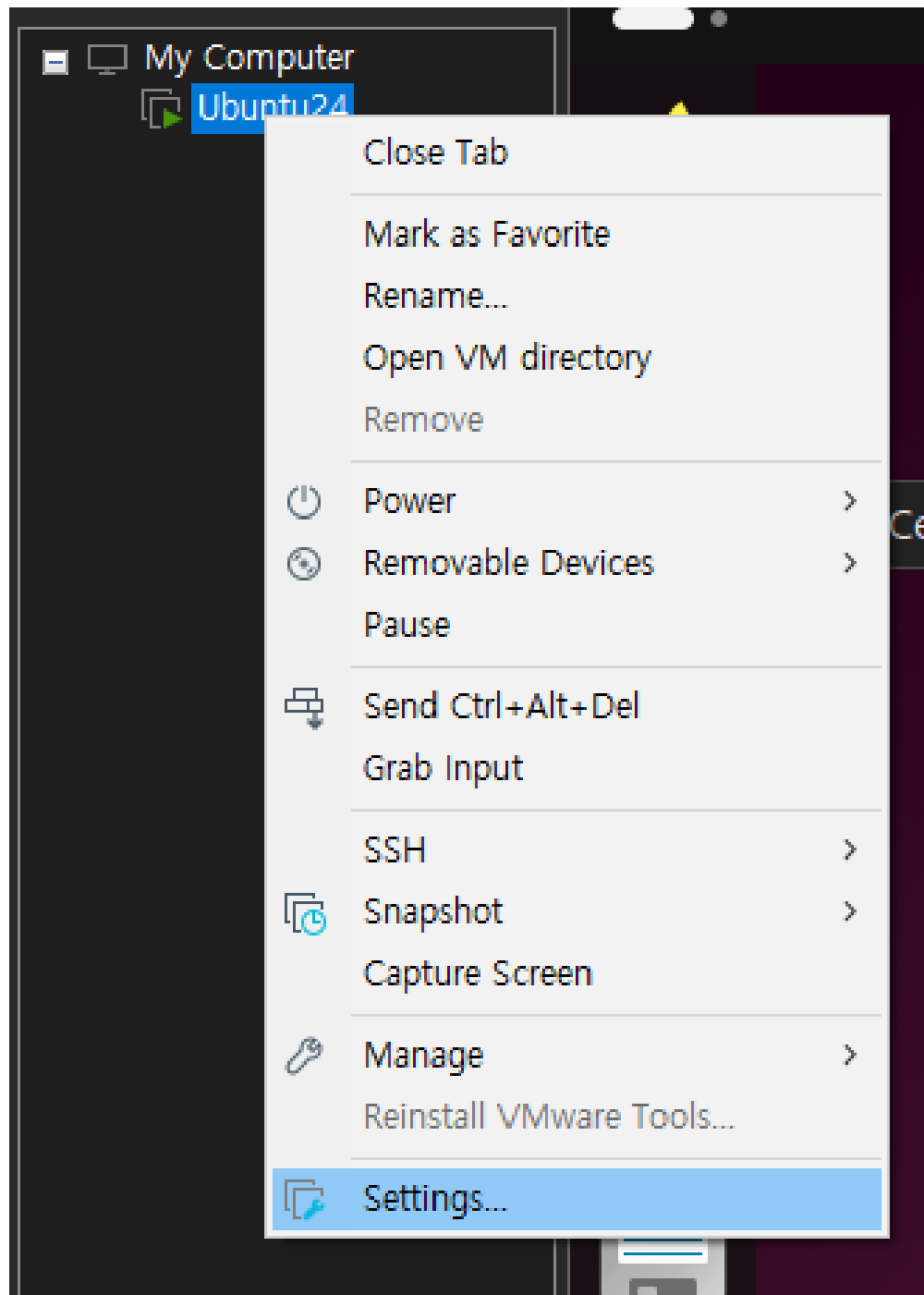
해당 창이 뜨면 각자 맞게 설정하여 vm에 ubuntu 설치

01 환경세팅 VMware에 ubuntu 설치



설치가 완료된 모습

01 환경세팅 VMware Tools 설치 및 간단한 설정



옵션에서 Shared Folders를 Always로 설정

01 환경세팅 VMware Tools 설치 및 간단한 설정



```
sudo apt update  
sudo apt install -y open-vm-tools open-vm-tools-desktop
```

위 명령어를 통해 vm tools 설치 후 reboot

01 환경세팅 pwntools & pwndbg 설치



```
sudo apt-get update
sudo apt-get install -y software-properties-common
sudo add-apt-repository -y universe
sudo apt-get update
sudo apt-get install -y python3 python3-pip python3-dev git \
    libssl-dev libffi-dev build-essential python3-pwntools
```

위 명령어를 통해 pwntools 설치

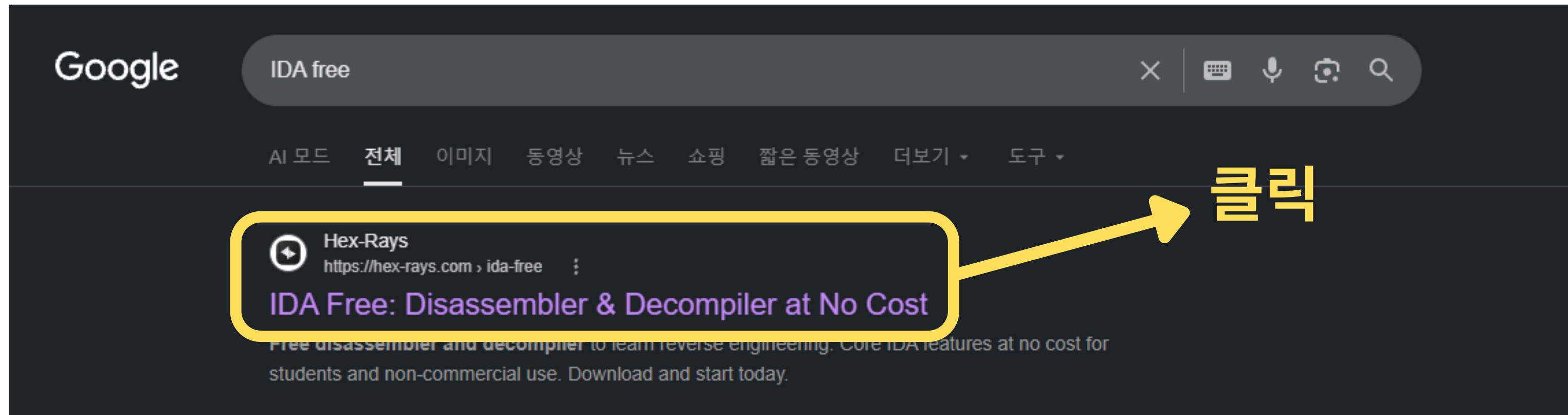
01 환경세팅 pwntools & pwndbg 설치



```
sudo apt update  
sudo apt install python3 python3-pip python3-dev git libssl-dev libffi-dev build-essential gdb  
git clone https://github.com/pwndbg/pwndbg  
cd pwndbg  
./setup.sh
```

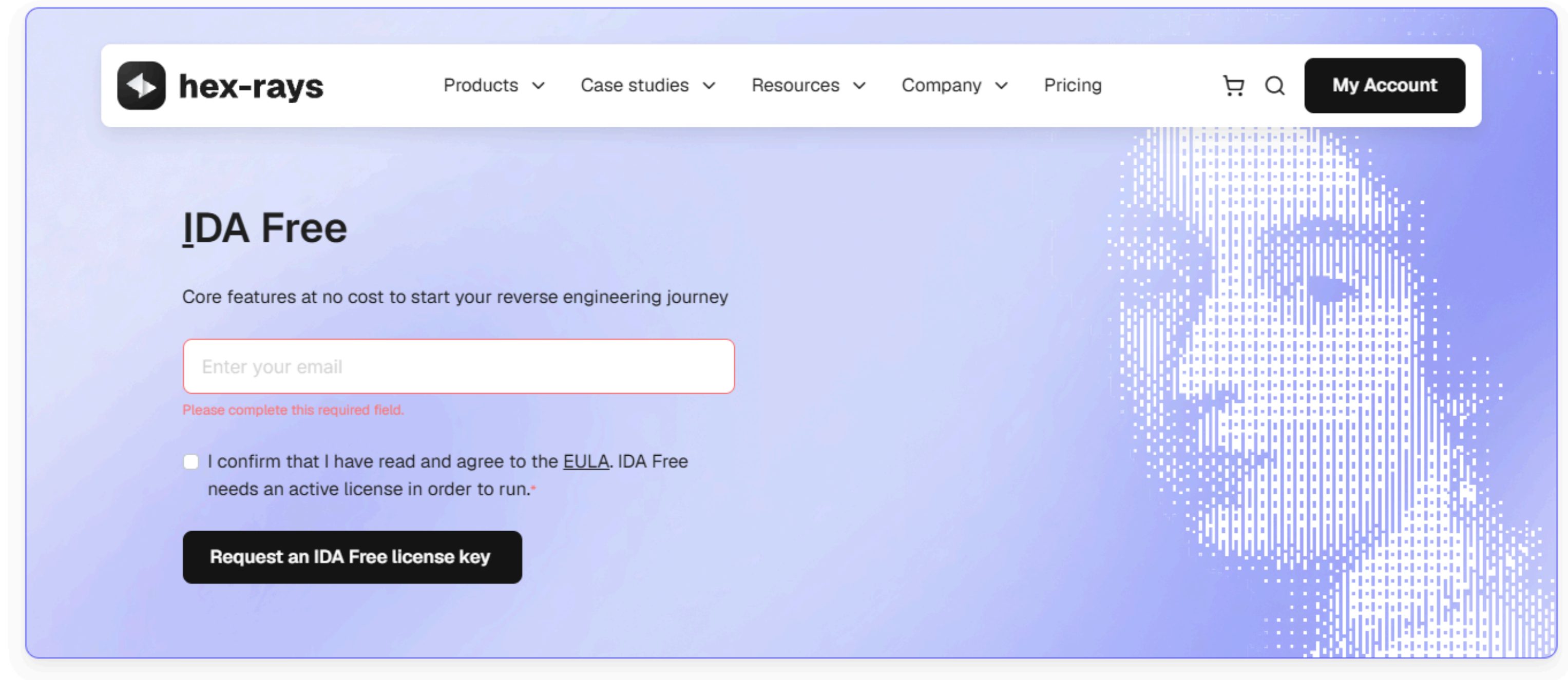
위 명령어를 통해 pwndbg 설치

01 환경세팅 IDA free 설치



IDA free를 검색하여 Hex-Rays 사이트를 접속

01 환경세팅 IDA free 설치



The screenshot shows the Hex-Rays website's IDA Free license request page. The header includes the Hex-Rays logo and navigation links for Products, Case studies, Resources, Company, and Pricing. A shopping cart icon and a 'My Account' button are also present. The main content area features the title 'IDA Free' and a subtitle 'Core features at no cost to start your reverse engineering journey'. Below this is a text input field for an email address, which is currently empty and has a red border. A red error message 'Please complete this required field.' is displayed below the input field. Underneath the input field is a checkbox that is currently unchecked, with the text 'I confirm that I have read and agree to the [EULA](#). IDA Free needs an active license in order to run.*'. At the bottom of the form is a black button with white text that reads 'Request an IDA Free license key'.

hex-rays

Products ▾ Case studies ▾ Resources ▾ Company ▾ Pricing

🛒 🔍 My Account

IDA Free

Core features at no cost to start your reverse engineering journey

Enter your email

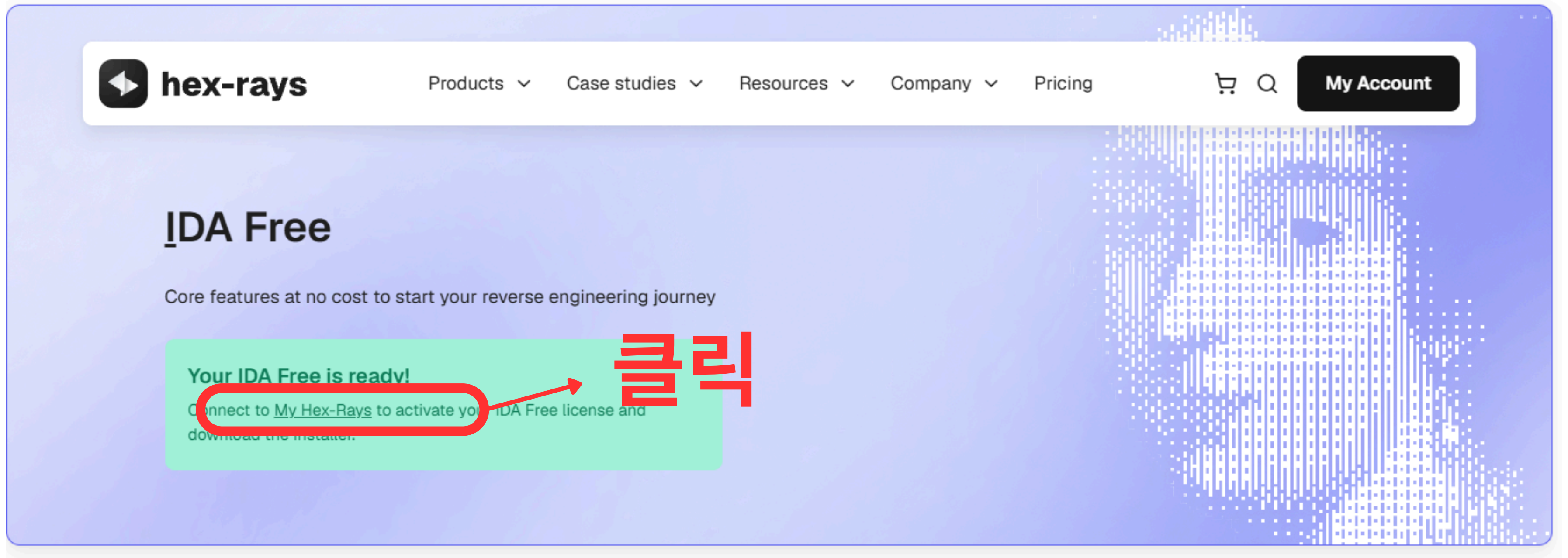
Please complete this required field.

☐ I confirm that I have read and agree to the [EULA](#). IDA Free needs an active license in order to run.*

Request an IDA Free license key

이메일을 입력하고 체크 박스를 표시 라이선스 키 받기

01 환경세팅 IDA free 설치



01 환경세팅 IDA free 설치

My hex-rays

OVERVIEW

Dashboard

LICENSES

Licenses

Servers

BILLING

Quotes

Invoices

SERVICES

Download center

My plugins

Shop

Documentation

Support

Download center > Installers > Release > IDA Free > 9.4

Release

IDA Free

9.4

9.3sp2

9.3sp1

9.3

9.2

9.1

9.0sp1

9.0

SDK and Utilities

Teams

Get IDA Free now!

IDA Free requires an active license. Please read carefully the [EULA](#).

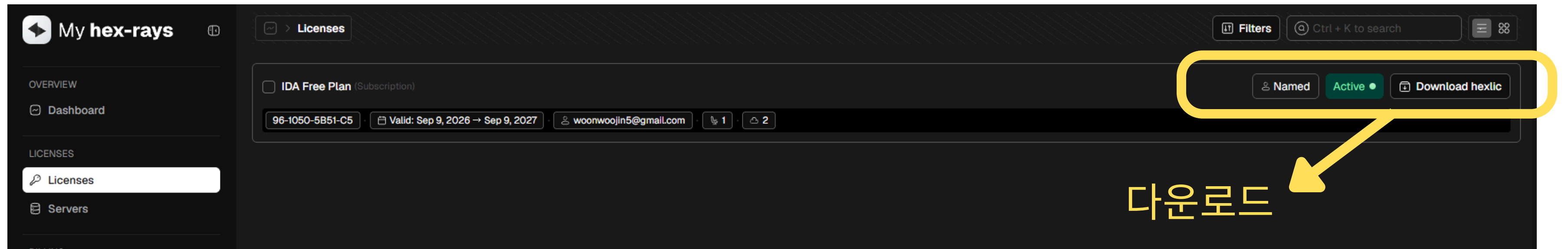
☐ I agree with the [terms & conditions](#)

Request an IDA Free license key

Name	Size	Last Updated	Actions
IDA Free Linux ARM64 9.4	363.8MB	Jul 14, 2026	↓
IDA Free Linux X64 9.4	379.5MB	Jul 14, 2026	↓
IDA Free Mac Apple Silicon 9.4	367.7MB	Jul 14, 2026	↓
IDA Free Mac Intel 9.4	367.3MB	Jul 14, 2026	↓
IDA Free Windows ARM64 9.4	385.4MB	Jul 14, 2026	↓
IDA Free Windows X64 9.4	411.2MB	Jul 14, 2026	↓

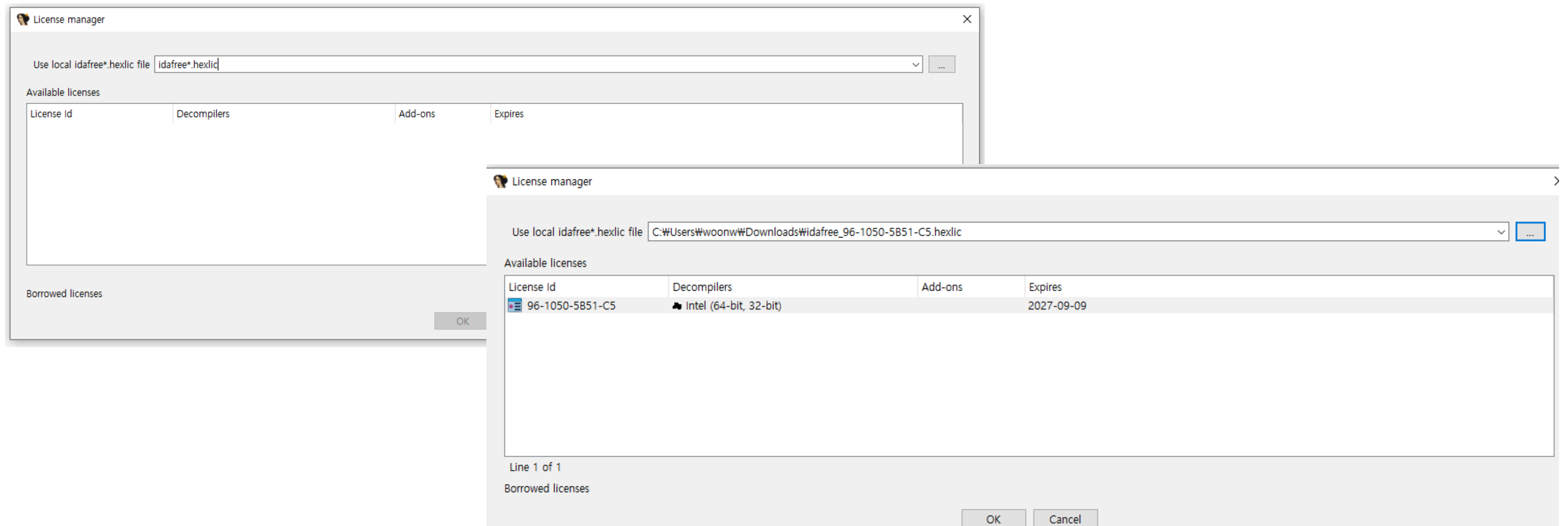
다운로드 센터에서 운영체제에 맞는 IDA 설치

01 환경세팅 IDA free 설치



Licenses 탭에서 Renew 누른 후 hexilc 파일 다운로드

01 환경세팅 IDA free 설치



이후 IDA를 설치하고 나오는 화면에서 받은 hexilc 넣기

02

pwntools 사용법

- 1.pwntools란?
- 2.pwntools 사용법
- 3.pwntools training

pwntools란?



CTF와 익스플로잇 개발을 위한 Python 기반 라이브러리로 프로그램 통신, 데이터 변환, 실행 파일 분석 등 포너블에서 반복되는 작업을 간편하게 처리하게 해주는 도구

pwntools 명령어



```
from pwn import *
```

Python으로 익스 코드를 작성할 때 가장 윗줄에 작성

pwntools의 기능을 현재 코드에서 쓸 수 있게 해주는 명령어

pwntools 명령어



```
from pwn import *  
  
p = process('./test')  
p = remote('example.com', 31337)
```

익스플로잇 코드가 데이터를 주고 받을 대상을 지정하는 코드

- process() : 로컬 프로그램을 실행하고 그 프로그램과 통신
- remote() : 지정한 서버 주소와 포트에 연결해 통신

pwntools 명령어



```
from pwn import *

p = process('./test')

p.send('A')
p.sendline('A')
p.sendafter('hello', 'A')
p.sendlineafter('hello', 'A')
```

프로그램이나 서버에 데이터를 보내는 함수

- send() : A라는 데이터를 그대로 보냄
- sendline() : A라는 데이터를 보내고 '\n' 개행문자 추가
- sendafter() : hello가 출력되고 나서 A를 보냄
- sendlineafter() : hello가 출력되고 나서 A를 보내고 '\n' 개행 문자 추가

pwntools 명령어



```
from pwn import *  
  
p = process('./test')  
  
data = p.recv(1024)  
data = p.recvline()  
data = p.recvn(5)  
data = p.recvuntil('hello')  
data = p.recvall()
```

프로그램이나 서버에서 데이터를 받는 함수

- `recv()` : 최대 1024 바이트까지 저장
- `recvline()` : 개행문자를 만날 때까지 저장
- `recvn()` : 5바이트만 저장
- `recvuntil()` : hello가 나올 때까지 저장
- `recvall()` : 모든 데이터를 받아서 저장

pwntools 명령어



```
from pwn import *  
  
p = process( './test' )  
  
p64( 0x41424344 )  
u64( b'ABCD' )
```

packing&unpacking 함수

- p64(), p32() : 정수 → 바이트 데이터
- u64(), u32() : 바이트 데이터 → 정수

pwntools 명령어



```
from pwn import *  
  
p = process( './test' )  
  
p64( 0x41424344 )  
u64( b'ABCD' )
```

packing&unpacking 함수

8바이트 이진 데이터로 만들어 보낼 때는 p64()를 사용하고, 받은 8바이트 이진 데이터를 정수로 해석할 때는 u64()를 사용한다.

pwntools 명령어



```
from pwn import *  
  
p = process('./test')  
  
p.interactive()
```

- interactive()를 호출하면 직접 터미널을 통해 입력하고 출력을 볼 수 있음

pwntools 명령어 - 실습1

01_menu — 랜덤 비밀번호 입력

실행할 때마다 16자리 숫자 비밀번호가 새로 생성됩니다. 이름을 입력한 뒤, 메뉴에서 비밀번호를 확인하고 제출합니다.

```
1) Read hint
2) Submit password
3) Quit
choice>
```

1. 이름을 입력합니다.
2. 메뉴에서 1번을 선택해 비밀번호를 확인합니다.
3. 메뉴에서 2번을 선택하고, `password>` 프롬프트에 비밀번호를 제출합니다.

2번을 선택한 뒤 1초 안에 비밀번호와 줄바꿈까지 입력해야 합니다. 이름 입력과 메뉴 선택에는 시간 제한이 없습니다.

- 정답을 제출하면 FLAG가 출력됩니다.
- 시간 안에 오답을 제출하면 메뉴로 돌아갑니다.
- 제한 시간을 초과하면 프로그램이 종료됩니다.

연습 내용: 메뉴 자동화, 출력에서 비밀번호 추출, `sendlineafter()` 로 프롬프트를 기다린 뒤 줄바꿈을 포함한 입력 전송.

- pwntools_training폴더의 1번 문제를 pwntools를 활용하여 풀어보자

pwntools 명령어 - 실습2

02_pack64 — 64비트 정수 전송

프로그램이 출력한 정수를 리틀 엔디언 형식의 8바이트로 변환해 제출합니다.

출력 예시:

```
value = 0x8877665544332211
bytes>
```

위 예시에서 전송해야 하는 8바이트를 16진수로 표시하면 다음과 같습니다.

```
11 22 33 44 55 66 77 88
```

위 내용을 문자로 입력하는 것이 아니라, 해당 값을 가진 **바이너리 바이트 8개**를 전송해야 합니다. 리틀 엔디언은 정수의 가장 낮은 자릿값에 해당하는 바이트부터 배치하는 방식입니다.

1. 출력에서 16진수 숫자 문자열을 읽습니다.
2. `int(읽은값, 16)` 으로 문자열을 정수로 변환합니다.
3. `p64()` 로 정수를 리틀 엔디언 8바이트로 변환합니다.
4. `bytes>` 프롬프트에 **추가 줄바꿈 없이** 전송합니다.

- 정답이면 FLAG가 출력되고, 오답이면 프로그램이 종료됩니다.
- 시간 제한은 없습니다.
- 8바이트보다 적게 보내면 프로그램은 나머지 입력을 기다립니다.

연습 내용: 문자열과 정수의 차이, 리틀 엔디언, `p64()`, `sendafter()` 로 줄바꿈을 추가하지 않고 바이트 전송.

- pwntools_training폴더의 2번 문제를 pwntools를 활용하여 풀어보자

pwntools 명령어 - 실습3

03_rounds — 3초 덧셈 계산기

0~9 사이의 랜덤 숫자 두 개를 더하는 문제가 총 10라운드 출제됩니다.

출력 예시:

```
ROUND 1/10  
3 + 5 =
```



위 예시에서는 8 과 줄바꿈을 제출합니다. 정답의 범위는 0~18이며, 계산한 정수를 숫자 문자열로 변환해 보냅니다.

시작 후 3초 안에 전체 10라운드를 완료해야 합니다. 라운드가 바뀌어도 제한 시간은 초기화되지 않습니다.

- 정답이면 다음 라운드로 진행합니다.
- 오답을 제출하거나 제한 시간을 초과하면 프로그램이 종료됩니다.
- 10라운드를 모두 맞히면 FLAG가 출력됩니다.

연습 내용: 출력에서 숫자 추출, 덧셈, `str(...)` 로 정수를 문자열로 변환, 반복문과 `sendline()` 으로 답 전송.

- pwntools_training폴더의 3번 문제를 pwntools를 활용하여 풀어보자

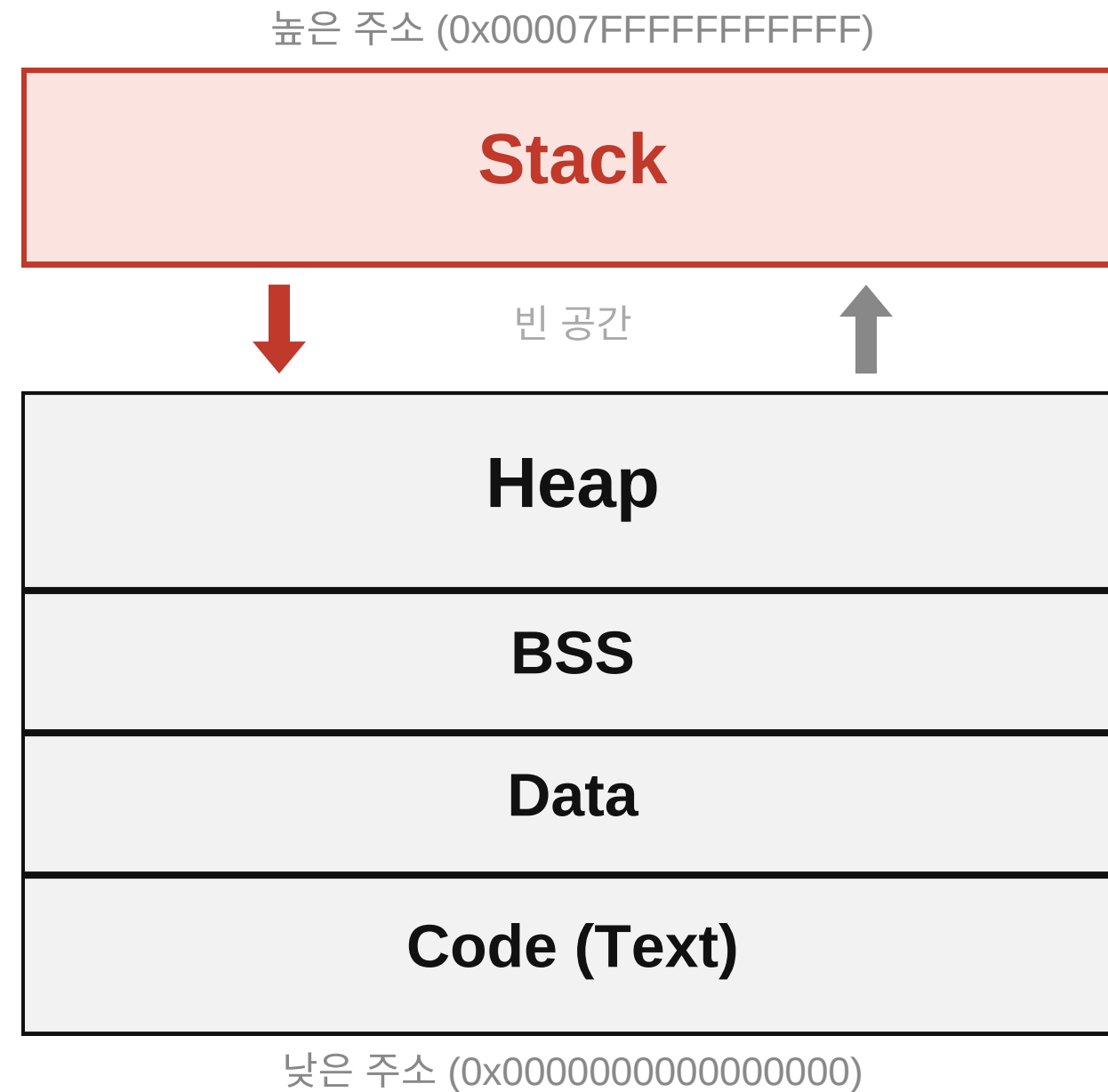
03

bof

- 프로세스 메모리 구조
- Buffer Overflow란?
- 실습



프로세스 메모리 구조



함수의 지역 변수, 매개변수, 복귀 주소(RET)가 저장되는 영역
높은 주소 → 낮은 주소 방향으로 자란다

malloc처럼 실행 중에 동적으로 할당받는 영역
낮은 주소 → 높은 주소 방향으로 자란다

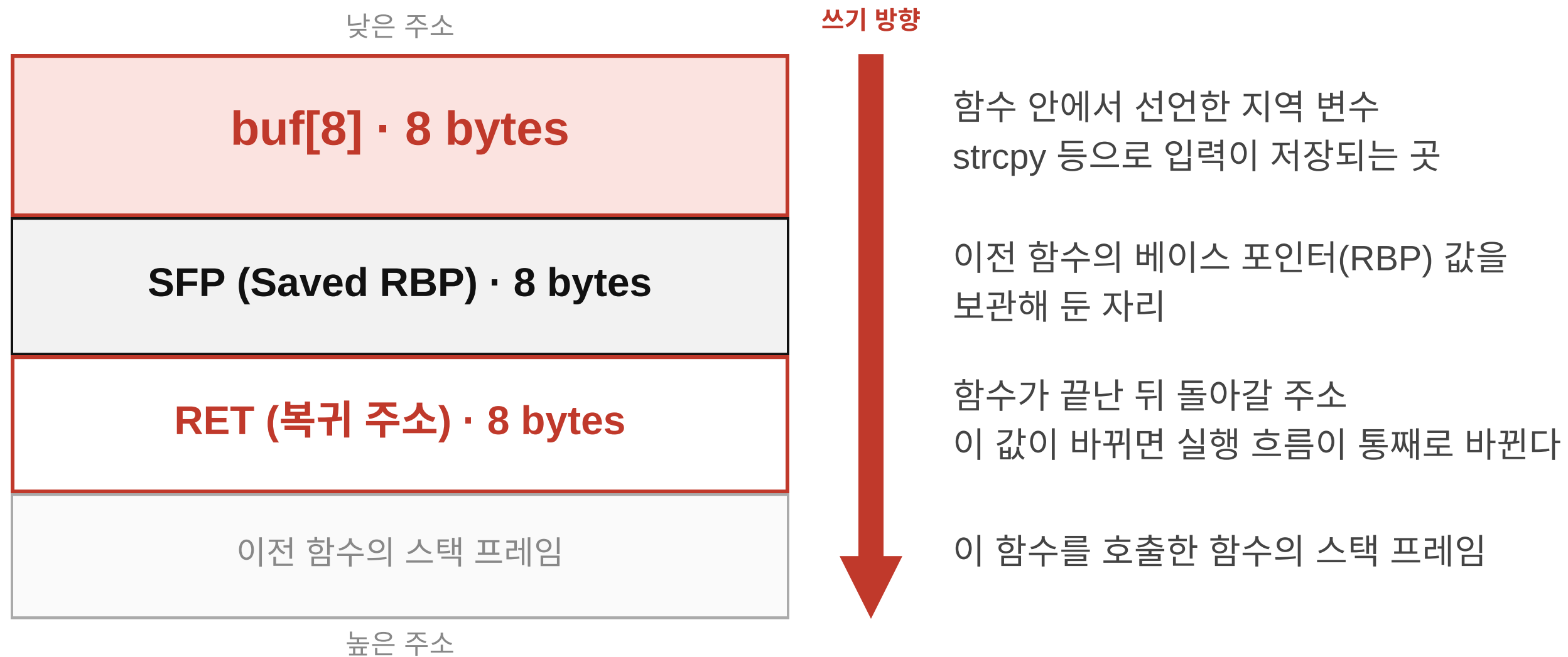
초기값 없이 선언한 전역 변수와 static 변수

초기값이 있는 전역 변수와 static 변수

실행할 기계어 코드가 담기는 읽기 전용 영역

버퍼 오버플로우는 이 중 Stack 영역에서 주로 발생한다

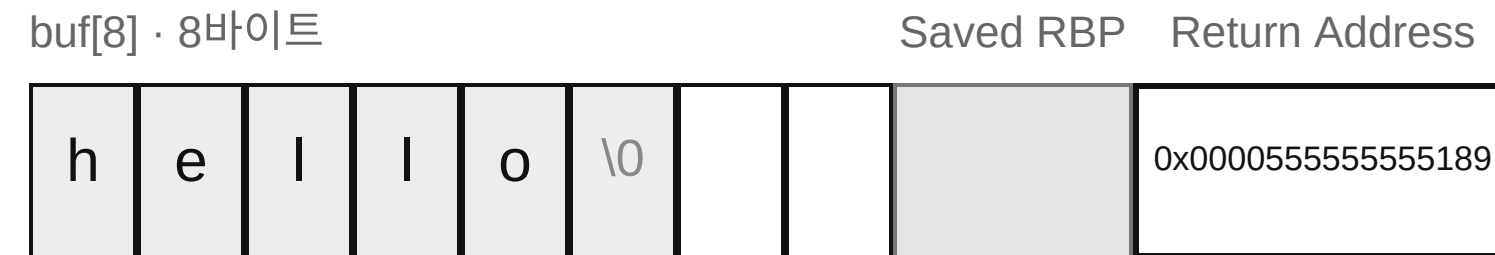
스택 프레임 구조



buf가 넘치면 SFP와 RET이 차례로 덮여 실행 흐름이 바뀐다

Buffer Overflow란?

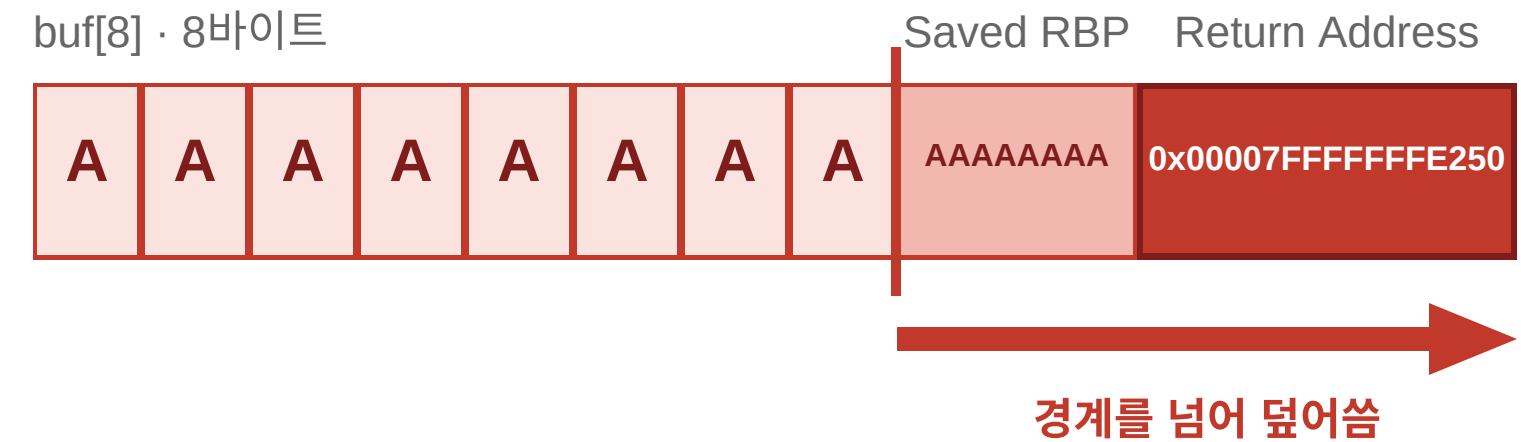
정상 입력 · input = "hello" (5바이트)



8바이트 안에 다 들어감 → 경계 침범 없음

함수 종료 후 원래 주소로 정상 복귀

오버플로우 · input = "AAAA..." (8바이트 초과)



변조된 주소로 점프 → 공격자 코드 실행

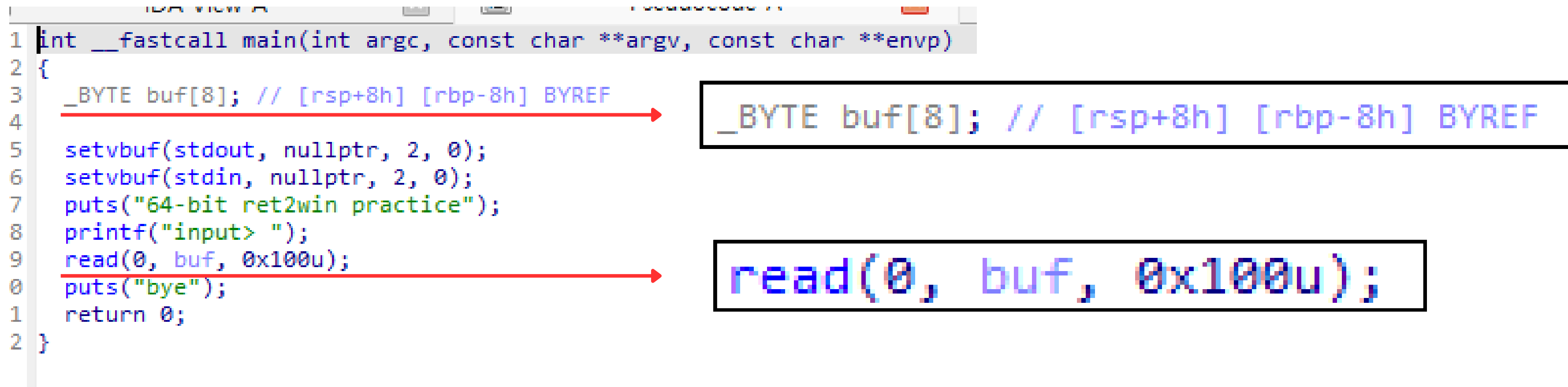
Buffer Overflow는 정해진 버퍼의 크기를 초과해 데이터를 기록하면서 버퍼 경계 밖의 메모리까지 덮어쓰는 현상

Buffer Overflow - 정적분석

```
1 int __fastcall main(int argc, const char **argv, const char **envp)
2 {
3     _BYTE buf[8]; // [rsp+8h] [rbp-8h] BYREF
4
5     setvbuf(stdout, nullptr, 2, 0);
6     setvbuf(stdin, nullptr, 2, 0);
7     puts("64-bit ret2win practice");
8     printf("input> ");
9     read(0, buf, 0x100u);
0     puts("bye");
1     return 0;
2 }
```

IDA를 활용하여 바이너리를 분석해보자

Buffer Overflow - 정적분석



```
1 int __fastcall main(int argc, const char **argv, const char **envp)
2 {
3     _BYTE buf[8]; // [rsp+8h] [rbp-8h] BYREF
4     setvbuf(stdout, nullptr, 2, 0);
5     setvbuf(stdin, nullptr, 2, 0);
6     puts("64-bit ret2win practice");
7     printf("input> ");
8     read(0, buf, 0x100u);
9     puts("bye");
10    return 0;
11 }
```

`_BYTE buf[8]; // [rsp+8h] [rbp-8h] BYREF`

`read(0, buf, 0x100u);`

buf의 크기는 8바이트, read로 읽는 수는 0x100바이트

Buffer Overflow - 정적분석

```
1 int win()  
2 {  
3     puts("\n[+] win() reached - spawning /bin/sh");  
4     return system("/bin/sh");  
5 }
```

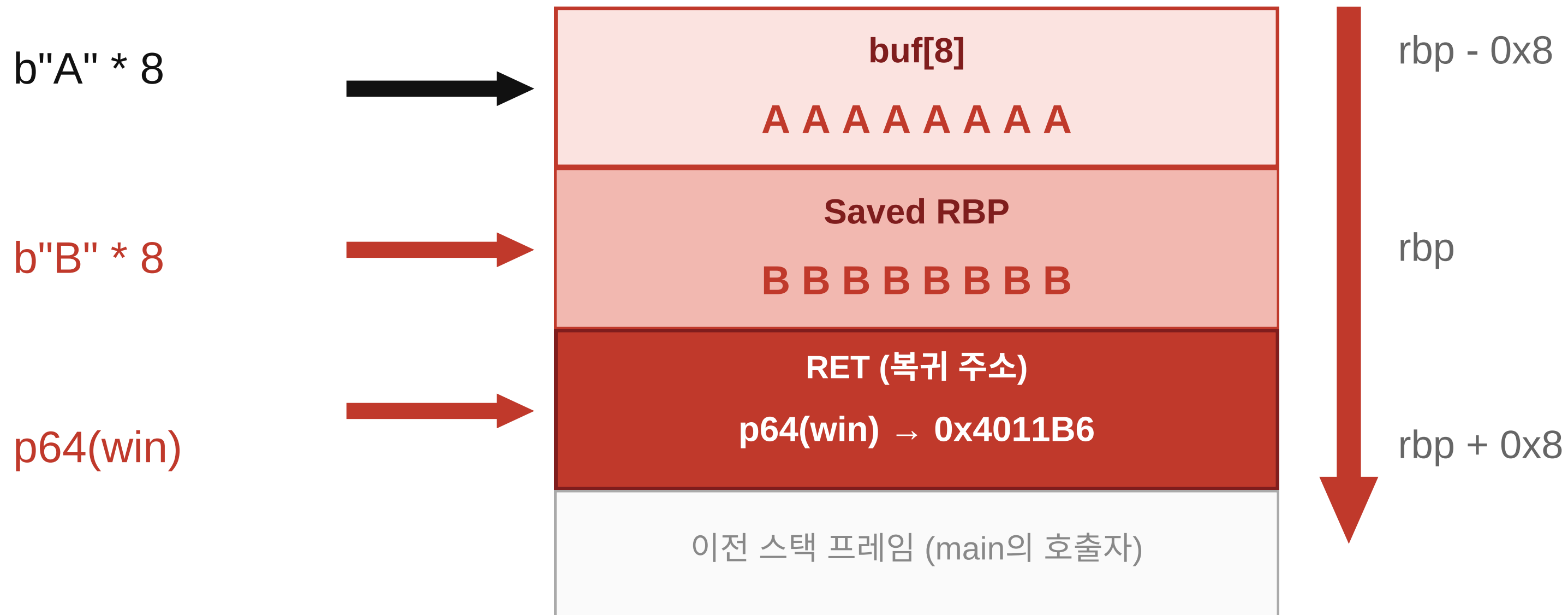
f	frame_dummy	.text	00000000004011D0	
f	win	.text	00000000004011B6	
f	main	.text	00000000004011E3	4011B6



4011B6주소에 shell을 획득할 수 있는 함수가 존재

실제로 오버플로우가 터지는 스택

입력 payload (24 bytes)



$buf(8) + Saved\ RBP(8) = 16$ 바이트를 채운 뒤 RET을 win 함수 주소로 덮으면 main 리턴 시 shell 실행

Buffer Overflow - 실습1

01. bof — 셸 호출 함수 실행

제공 파일: [bof](#)

바이너리 안에 셸을 호출하는 함수가 존재합니다.

프로그램을 분석하고, 해당 함수를 호출해 셸이 실행되도록 하는 것이 목표입니다.

BufOverflow 폴더의 1번 bof를 풀어보자

Buffer Overflow - 실습2

02. password_bof — 비밀번호 변경

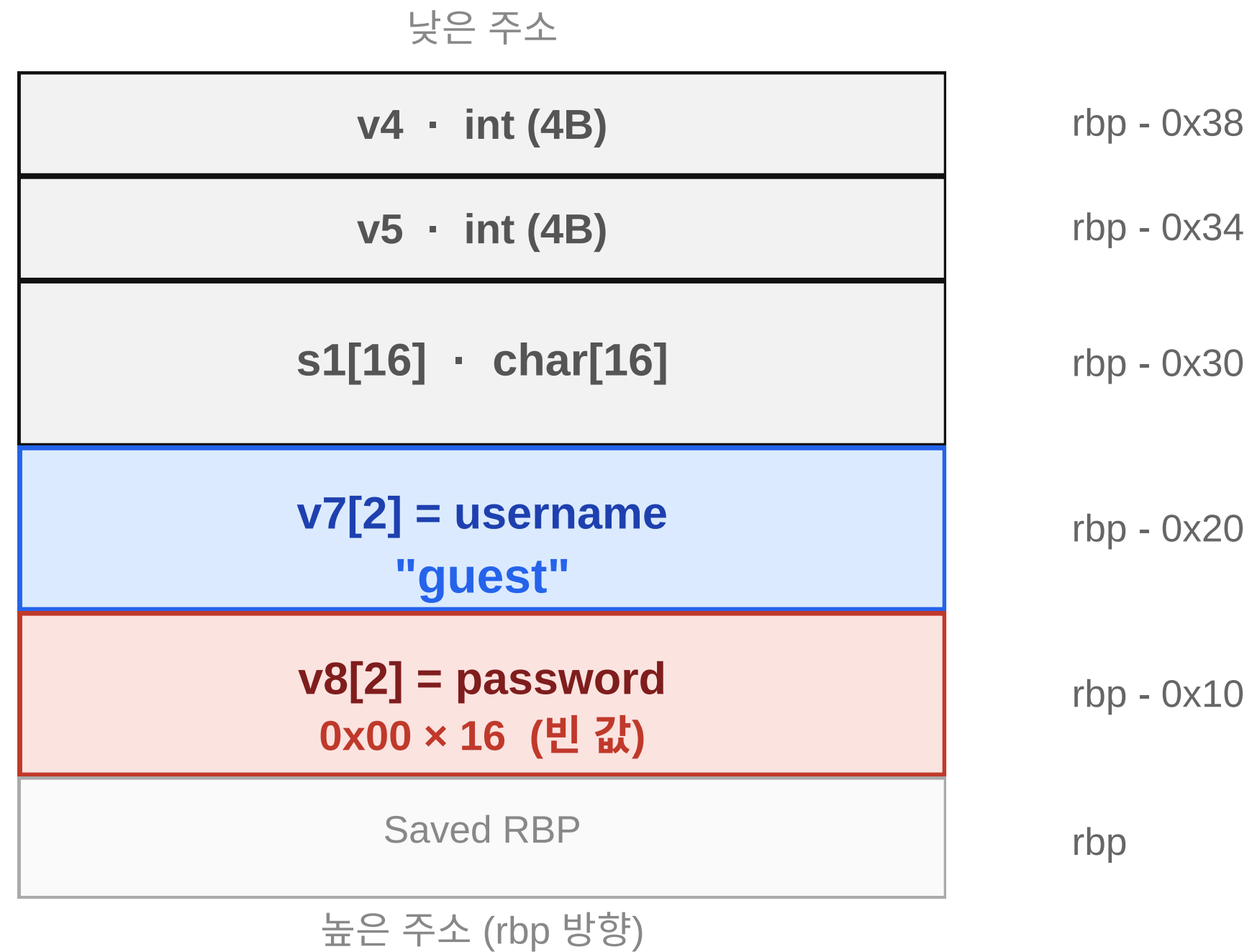
제공 파일: [password_bof](#)

버퍼 오버플로를 이용해 프로그램 내부의 비밀번호 값을 변경하는 문제입니다.

비밀번호를 변경한 뒤, 변경한 비밀번호를 입력해 셸을 얻는 것이 목표입니다.

BufOverflow 폴더의 2번 password_bof를 풀어보자

Buffer Overflow - 실습2



password_bof 스택 구조

03

스택 카나리

1. 카나리란?
2. 카나리 leak
3. 실습

카나리의 기원



19,20세기 탄광에서 일산화탄소 농도 측정 기술이 부족했고 이 때문에 카나리아라는 새를 이용
카나리아는 유독가스에 민감 했기 때문에 사람이 중독되기 전에 먼저 죽게됨
이후 카나리아는 위험을 알려주는 새로 상징적 의미를 가지게 됨

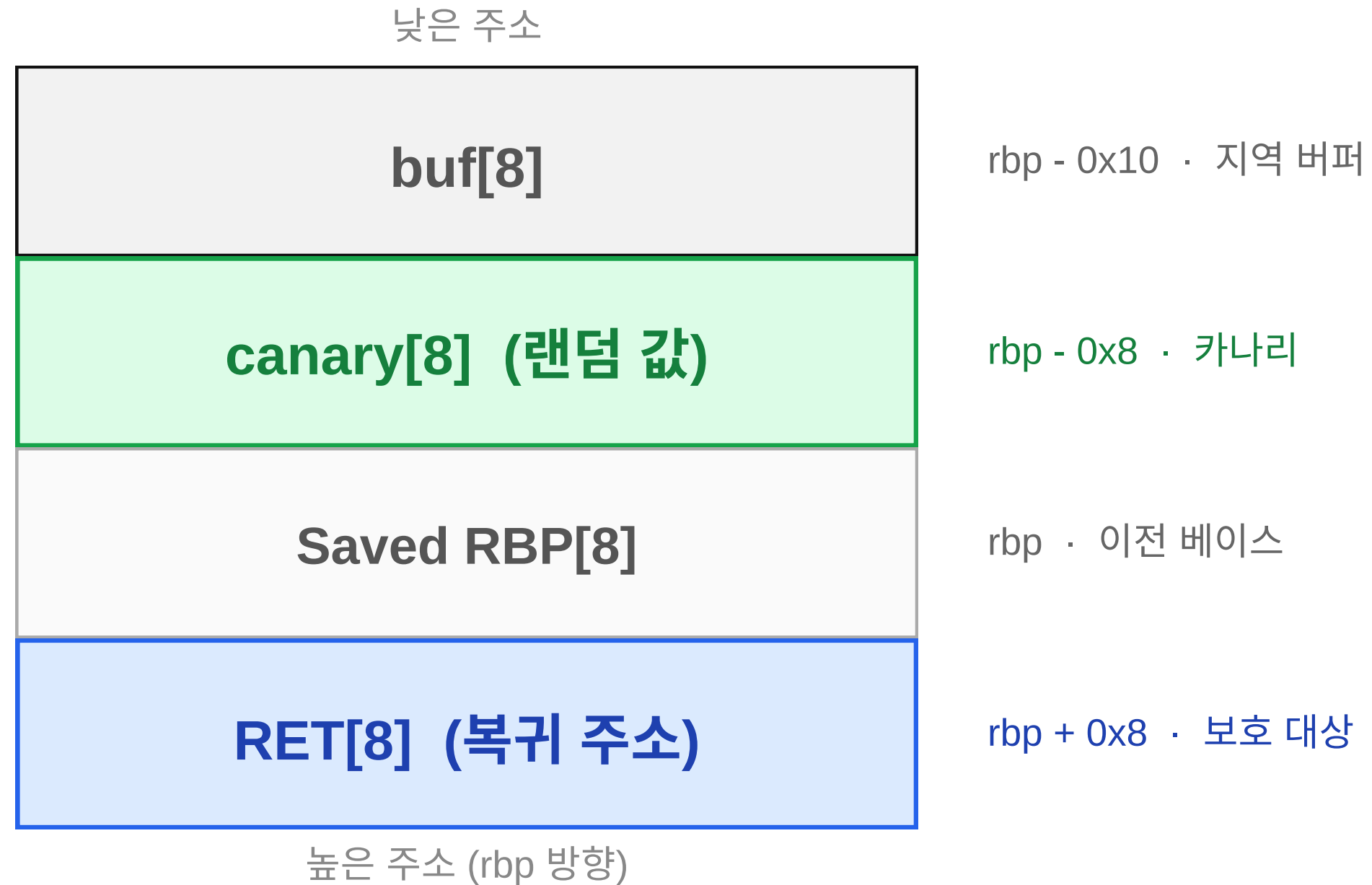
카나리의 기원



소프트웨어를 출시하거나 업데이트할 때 베타 테스트 용도로 공개하는 버전을 카나리 버전이라고 부르는 것도 이런 의미가 반영, 카나리 보호 기법도 반환 주소가 덮인 것을 알려준다는 의미에서 “카나리”로 이름이 붙게 되었다.

카나리 생성 위치

함수 진입 시 컴파일러가
buf와 Saved RBP 사이에
canary를 자동으로 삽입한다



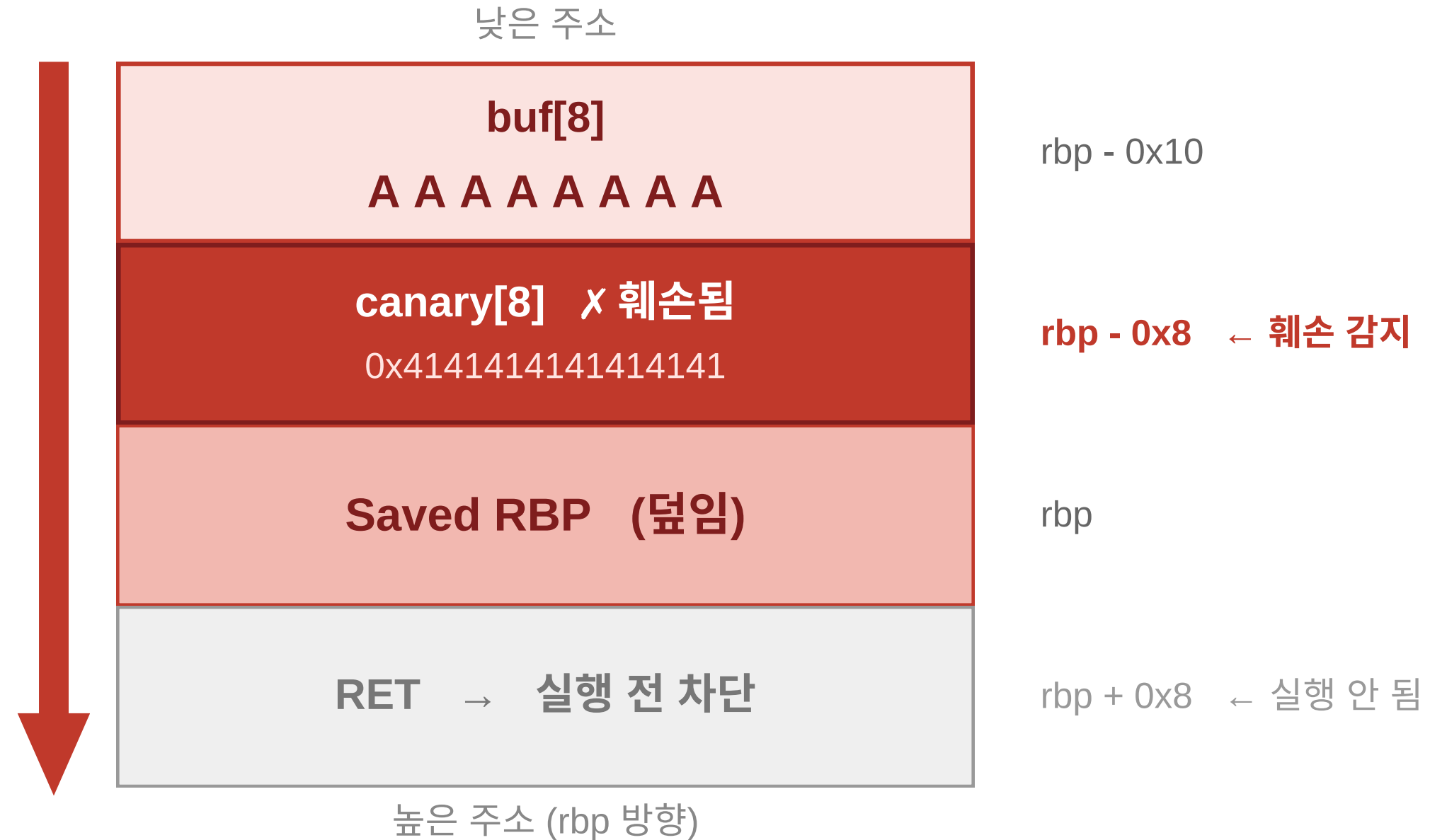
canary는 지역 버퍼(buf) 바로 뒤, Saved RBP·RET 앞에 자리한다

03 스택 카나리

오버플로우가 카나리에 걸리는 과정

오버플로우 발생

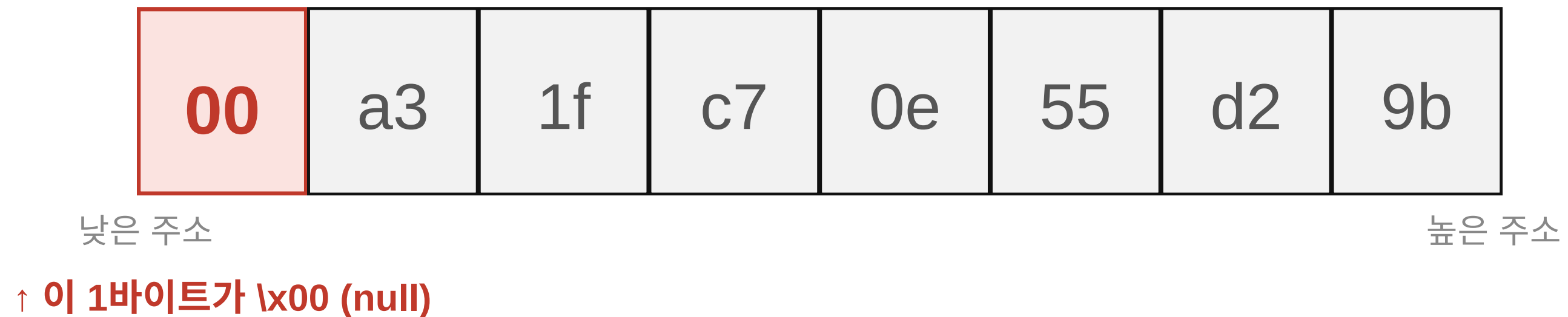
- ① buf를 넘겨 입력이 쓰임
- ② canary까지 덮여 랜덤 값이 바뀜
- ③ 종료 직전 검사에서 카나리 불일치 감지



canary 값이 바뀌었으므로 함수 종료 시 `__stack_chk_fail()` 호출 → RET 실행 전에 프로그램을 강제 종료

카나리의 끝은 null 바이트

canary · 8 bytes (리틀엔디안)



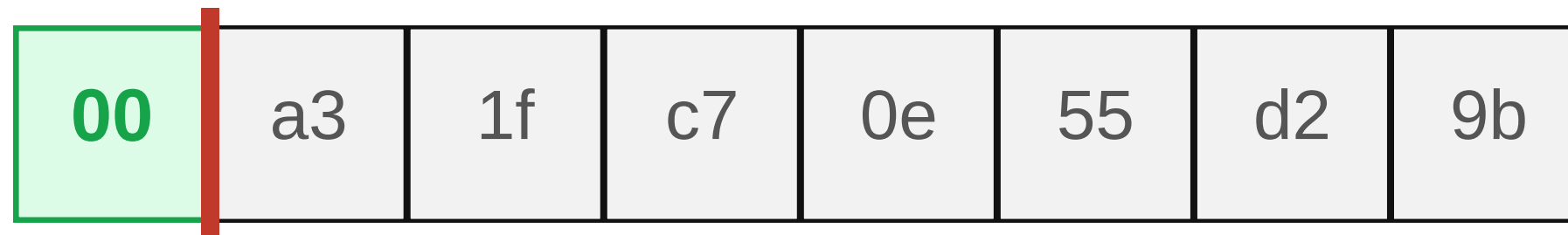
왜 끝이 null 바이트일까?

- ① printf("%s") · strlen · puts 같은 문자열 함수는 \x00을 만나면 멈춘다
→ 카나리가 실수로 출력·복사되어 새어나가는 것을 막는다
- ② 오버플로우로 카나리를 덮을 때도 입력에 \x00을 넣기 어렵다
→ 원래 값 그대로 복원하기 까다롭게 만든다

리눅스 64비트 카나리는 최하위 1바이트가 항상 0x00 → 낮은 주소 쪽 1칸이 null

null 바이트를 이용한 카나리 leak

① 원래 카나리 — 출력이 null(00)에서 멈춤



puts / printf가 00에서 멈추어 카나리가 출력되지 않는다



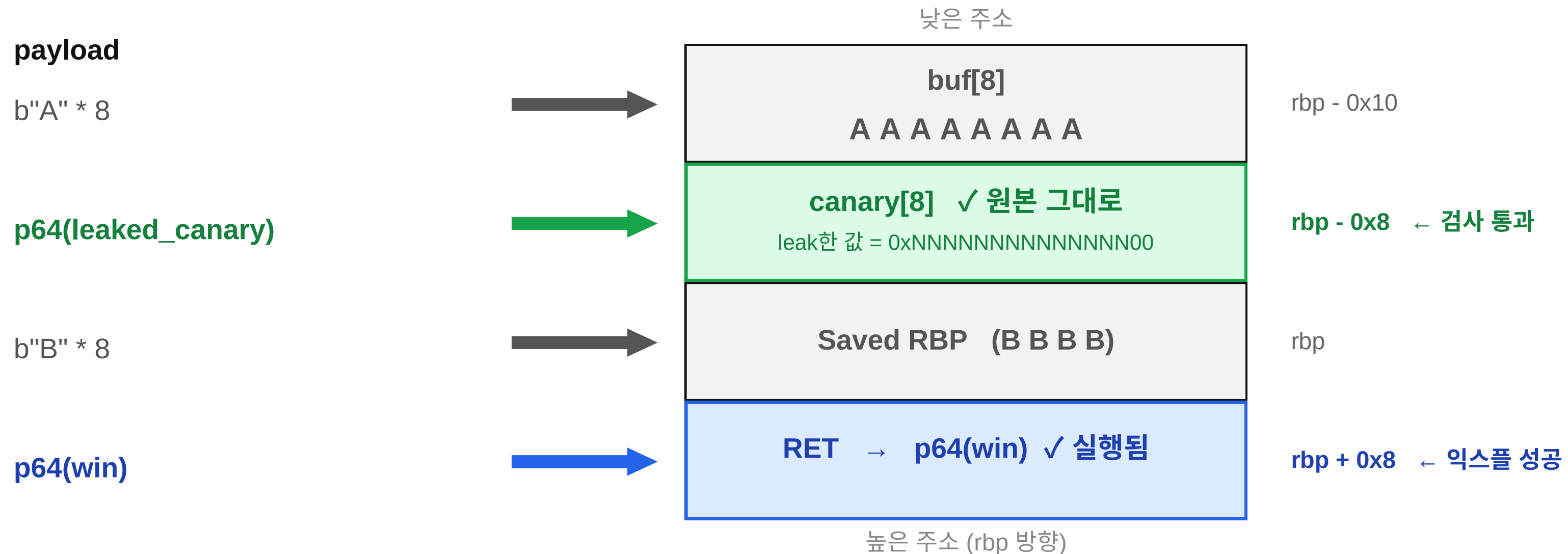
② buf를 딱 채워 null 1바이트를 덮음 (00 → 0a)



멈추는 null이 사라져 출력이 계속 → 뒤 7바이트가 팔려 나온다

출력에서 얻은 7바이트 = 카나리 상위 7바이트 → `canary = b"\x00" + leaked` 로 복원

카나리 우회 — canary leak



카나리를 먼저 leak해 payload의 카나리 자리에 그대로 넣으면, 검사가 통과되면서 RET 덮어쓰기가 성공한다

카나리 우회 — canary leak 실습

01. canary_leak — 카나리 누출 연습

제공 파일: [canary_leak](#)

오버플로를 통해 카나리의 널 바이트를 덮어 카나리 누출(leak)을 연습하는 문제입니다.

널 바이트를 덮었을 때 나타나는 정보 누출을 관찰하며, 스택 카나리의 널 바이트와 정보 누출의 관계를 이해하는 것이 목표입니다.

바이너리를 분석해 카나리의 null 바이트를 덮어 카나리를 출력해보자

카나리 우회 — canary leak 실습2

01. canary_leak — 카나리 누출 연습

제공 파일: [canary_leak](#)

오버플로를 통해 카나리의 널 바이트를 덮어 카나리 누출(leak)을 연습하는 문제입니다.

널 바이트를 덮었을 때 나타나는 정보 누출을 관찰하며, 스택 카나리의 널 바이트와 정보 누출의 관계를 이해하는 것이 목표입니다.

바이너리를 분석해 카나리의 null 바이트를 덮어 카나리를 출력해보자